

VirtuEx 시스템 감사 보고서 (4차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 4차 감사 작성일: 2026-03-02 작성: 시스템 감사팀

1. 개요

4차 감사는 1~3차 감사에서 수정 완료된 86건 이후 신규 발견된 이슈를 대상으로 합니다. 백엔드 8개 서비스, 프론트엔드(Next.js 15), 인프라(Docker/Kafka/모니터링), 빌드/환경 설정 전체를 정밀 점검하여 총 **79건**의 신규 이슈를 식별했습니다.

1.1 감사 범위

영역	발견 이슈
보안 (백엔드 + 인프라 + 프론트엔드)	12건
데이터 무결성	8건
성능	7건
코드 품질 — 백엔드	7건
인프라/빌드/환경	24건
프론트엔드 코드 품질	5건
프론트엔드 i18n	9건
프론트엔드 접근성	3건
프론트엔드 상태/UX	4건
합계	79건

2. 보안 감사 (12건)

#	항목	위험도	파일	상태
1	Settings 프로ksi 전체 헤더 전달	상	api-gateway/.../settings-proxy.controller.ts:16	
2	페이지뷰 트래킹 path 미검증 (무인증)	상	user-auth/.../statistics.controller.ts:30-34	
3	환경 파일 (.env.development/staging/production) Git 추적	상	.gitignore	
4	시드 파일 개인정보 하드코딩 (비밀번호/주민번호/전화번호)	상	user-auth/prisma/seed.ts:37,43,55-57	

5	프론트엔드 accessToken localStorage 저장	상	frontend/src/stores/auth.ts:37-41	●
6	공지사항 viewCount 무인증 무제한 증가	중	api-gateway/.../announcement-proxy.controller.ts:229-244	●
7	Email 서비스 에러 로그에 실제 이메일 노출	중	notification/src/email/email.service.ts:77	●
8	ThrottlerModule ConfigService 미사용 (하드코딩)	중	api-gateway/src/app.module.ts:29-39	●
9	price-subscriber refreshAlerts 빈 catch 블록	중	api-gateway/.../price-subscriber.service.ts:114-116	●
10	채팅방 join-room 권한 미검증	중	api-gateway/.../chat.gateway.ts:98-111	●
11	statistics page-view 프록시 미인증	중	api-gateway/.../statistics-proxy.controller.ts:28-38	●
12	Next.js 보안 헤더 불완전 (HSTS, CSP 누락)	중	frontend/next.config.ts:13-24	●

상세 (상 위험도)

#1 headers: req.headers 로 클라이언트 전체 HTTP 헤더를 내부 서비스에 전달. Host, Content-Length 등 위험 헤더 포함 → 헤더 인젝션 위험. 수정: 필요한 헤더만 명시적 전달

#2 POST /statistics/page-view 에서 body.path 를 검증 없이 DB 저장. 인증 불필요 → DB 소진 DoS 위험. 수정: 길이 제한(500자) + 형식 검증 + 속도 제한

#3 .env.development/.staging/.production 이 Git에 추적됨. 개발용 시크릿·호스트명 노출. 수정: .gitignore 에 추가 후 git rm --cached 실행

#4 seed.ts 에 실제 비밀번호(ehgm15516!), 주민등록번호(9311171052812), 전화번호, 실명, 주소 하드코딩. 수정: 환경변수 또는 가상 데이터로 교체

#5 Zustand persist 의 partialize 에서 accessToken 을 localStorage에 저장 → XSS 시 탈취 위험. 수정: partialize 에서 accessToken 제거, 메모리만 유지

3. 데이터 무결성 (8건)

#	항목	위험도	파일	상태
13	Portfolio marketDataUrl 기본값 오류 (3003→3001)	상	portfolio/.../balance.service.ts:68-71	●
14	Settings bulkUpdate 트랜잭션 미적용	중	user-auth/.../settings.service.ts:19-28	●
15	order.service getUserOrders any 타입	중	order-engine/.../order.service.ts:280	●
16	announcement.service 댓글 매핑 any 타입	중	user-auth/.../announcement.service.ts:147,155	●

17	order.service withRetry any 타입	중	order-engine/.../order.service.ts:557	●
18	balance.service toBalanceInfo/toHoldingInfo any 타입	중	portfolio/.../balance.service.ts:810-811,826-829	●
19	market-data \$executeRawUnsafe 사용	중	market-data/.../market-data.service.ts:402	●
20	statistics period 쿼리 파라미터 미검증	하	user-auth/.../statistics.controller.ts:71,128,154	●

#13 (상) MARKET_DATA_URL 기본값이 http://localhost:3003 (portfolio 자신의 포트). market-data는 3001번 포트 → 자기 참조 무한 루프. 수정: 기본값을 http://localhost:3001 로 변경

4. 성능 감사 (7건)

#	항목	위험도	파일	상태
21	getTradingStats 전체 주문 메모리 로드	상	order-engine/.../order.service.ts:308-361	●
22	statistics 컨트롤러 대량 레코드 메모리 로드	상	user-auth/.../statistics.controller.ts:78-82	●
23	aggregateHigherIntervals 심볼별 2회 추가 쿼리	중	market-data/.../market-data.service.ts:448-461	●
24	fetchMarketPrices 내부 토큰 미전달	중	portfolio/.../balance.service.ts:790-806	●
25	채팅 통계 raw SQL bigint 캐스팅	하	chat/src/chat/chat.service.ts:524-535	●
26	leaderboard fetch more 전략 비효율	중	portfolio/.../balance.service.ts:700-703	●
27	news scrapeAll 초기화 시 isScraping 플래그 누락	하	market-data/.../news.service.ts:143-146	●

#21 (상) getTradingStats(days) 메서드가 모든 주문을 findMany 로 메모리 로드 후 JS에서 집계 → OOM 위험. 수정: Prisma groupBy + _sum / _count DB 집계

#22 (상) registrationStats, loginStats 등에서 days 파라미터 상한 없이 전체 레코드 로드 → ? days=99999 시 전체 테이블 로드. 수정: days 상한(365) + DB 집계

5. 코드 품질 — 백엔드 (7건)

#	항목	위험도	파일	상태
28	order.service validateHoldings any 타입	중	order-engine/.../order.service.ts:790	●

29	order.service reserveFunds any 타입	중	order-engine/.../order.service.ts:726	●
30	MatchingEngine 인메모리 오더북 복구 불가	중	order-engine/.../matching-engine.service.ts	●
31	Announcement 알림 생성 실패 무시	하	user-auth/.../announcement.service.ts:231-241	●
32	news.service 개별 아이템 실패 시 빈 catch	하	market-data/.../news.service.ts:221-223	●
33	TOTP verify 브루트포스 방지 없음	중	user-auth/.../totp.service.ts:62-81	●
34	chat deleteRoom 트랜잭션 미적용	중	chat/src/chat/chat.service.ts:476-483	●

#30 매칭 엔진 오더북이 순수 인메모리(Map). 서비스 재시작 시 PENDING 지정가 주문 복원 안 됨. 수정: `onModuleInit` 에서 PENDING 주문 DB 로드

#33 TOTP 6자리(100만 가지), `window: 1` 로 2개 유효 → 자동화 브루트포스 ~50만회 내 성공. 수정: Redis 기반 시도 횟수 제한(5회 실패 시 5분 잠금)

6. 인프라/빌드/환경 (24건)

6.1 Docker (5건)

#	항목	위험도	파일	상태
35	docker-compose.yml 레거시 version 키	하	docker-compose.yml:1	●
36	Redis 인증 미적용 (requirepass 없음)	중	docker-compose.yml:45	●
37	Prometheus/Grafana/Jaeger 헬스체크 미설정	중	docker-compose.yml:192-248	●
38	Prometheus/Grafana/Jaeger 리소스 제한 미설정	중	docker-compose.yml:192-248	●
39	PostgreSQL healthcheck 환경변수 미참조	하	docker-compose.yml:22	●

6.2 빌드 설정 (5건)

#	항목	위험도	파일	상태
40	NestJS 보조 패키지 버전 불일치 (chat/notification/ai-service)	중	3개 서비스 package.json	●
41	class-validator 버전 불일치 (notification)	하	notification/package.json:26	●
42	@prisma/client 버전 불일치 (chat ^6.0.0 vs ^6.3.0)	하	chat/package.json:26	●
43	chat 서비스 Prisma DB 스크립트 누락	하	chat/package.json	●

44	turbo.json build outputs에 Prisma generated 미 포함	중	turbo.json:7	●
----	---	---	--------------	---

6.3 데이터베이스 (3건)

#	항목	위험도	파일	상태
45	PriceHistory/LoginLog/PageView 데이터 보존 정책 부재	중	market-data/user-auth schema.prisma	●
46	Event Store Outbox 정리 정책 부재	중	event-store/src/event-store.service.ts:80-93	●
47	Transaction 모델 type 필드 enum 미적용	하	portfolio/prisma/schema.prisma:44	●

6.4 환경변수 (5건)

#	항목	위험도	파일	상태
48	.env.example에 CORS_ORIGIN 누락	중	.env.example	●
49	.env.example에 MARKET_DATA_URL, PORTFOLIO_URL 누락	중	.env.example	●
50	.env.example에 GRAFANA_ADMIN_USER 누락	하	.env.example	●
51	.env 환경별 파일 인증 설정(SALT_ROUNDS 등) 누락	중	.env.development/.staging/.production	●
52	.env에 개인 연락처 하드코딩	하	.env:71-72	●

6.5 스크립트 (4건)

#	항목	위험도	파일	상태
53	start-all.sh Kafka 토픽명 불일치	상	scripts/start-all.sh:282	●
54	backup-db.sh 단일 DB만 백업 (6개 서비스 DB 미포함)	중	scripts/backup-db.sh:14	●
55	phase2/setup-git 스크립트 프로젝트 경로 오류	하	scripts/phase2-build-and-commit.sh:4	●
56	BigInt.prototype.toJSON 전역 변경 미제거 (order-engine/market-data)	중	order-engine/src/main.ts:14, market-data/src/main.ts:14	●

6.6 모니터링 (2건)

#	항목	위험도	파일	상태
57	Prometheus 알림 규칙 미설정	중	infrastructure/docker/prometheus/prometheus.yml	●
58	Grafana 데이터 소스 자동 프로비저닝 미설정	하	docker-compose.yml:210-229	●

#53 (상) start-all.sh 에서 생성하는 Kafka 토픽명(price.updated , order.events , trade.events)이 실제 코드(market.prices.updated , orders.events , trades.executed)와 불일치.

KAFKA_AUTO_CREATE_TOPICS_ENABLE=false → 메시지 발행/소비 실패. 수정: 실제 토픽명으로 수정

7. 프론트엔드 감사 (21건)

7.1 코드 품질 (5건)

#	항목	위험도	파일	상태
59	useLeaderboard any[] 및 any 타입 사용	중	frontend/src/hooks/useLeaderboard.ts:32-33	●
60	로그인 페이지 user: any 타입 사용	중	frontend/src/app/(auth)/login/page.tsx:79	●
61	대시보드 rawPrices as any[] 타입 캐스팅	중	frontend/src/app/(main)/dashboard/page.tsx:106	●
62	관리자 통계 Recharts label any 타입	하	frontend/src/app/(main)/admin/stats/page.tsx:1381	●
63	PageViewTracker eslint-disable 사용	하	frontend/src/components/layout/PageViewTracker.tsx:22	●

7.2 i18n — 국제화 (9건)

#	항목	위험도	파일	상태
64	ChatPanel 채팅방 나가기 확인 한국어 하드코딩	중	frontend/src/components/chat/ChatPanel.tsx:120	●
65	MessageArea '(me)' 영어 하드코딩	하	frontend/src/components/chat/MessageArea.tsx:221	●
66	MessageArea 'Kick' title 영어 하드코딩	하	frontend/src/components/chat/MessageArea.tsx:227	●

67	useChat 메시지 전송 실패 한국어 하드코딩	중	frontend/src/hooks/useChat.ts:77	●
68	AiInsights 에러 상태 한국어 하드코딩	중	frontend/src/components/trading/AiInsights.tsx:88	●
69	MobileMenuButton aria-label 한국어 하드코딩	중	frontend/src/components/layout/MobileMenuButton.tsx:17	●
70	관리자 설정 저장 실패 한국어 하드코딩	중	frontend/src/app/(main)/admin/settings/page.tsx:174	●
71	마이페이지 알림 설정 실패 한국어 하드코딩	중	frontend/src/app/(main)/mypage/page.tsx:70	●
72	OrderBook 'No data' 영어 하드코딩	하	frontend/src/components/trading/OrderBook.tsx:87	●

7.3 접근성 (3건)

#	항목	위험도	파일	상태
73	OrderSheet 모달 role="dialog" 누락	중	frontend/src/components/trading/OrderSheet.tsx:61	●
74	SpotlightSearch 모달 role="dialog" 누락	중	frontend/src/components/market/SpotlightSearch.tsx:100	●
75	마이페이지 비밀번호 변경 모달 ARIA/포커스 트랩 미적용	중	frontend/src/app/(main)/mypage/page.tsx:395-523	●

7.4 상태 관리 / UX (4건)

#	항목	위험도	파일	상태
76	MessageArea eslint-disable (자동 스크롤)	하	frontend/src/components/chat/MessageArea.tsx:116	●
77	공지사항 상세 eslint-disable (조회수 증가)	하	frontend/src/app/(main)/announcements/[id]/page.tsx:66	●
78	PinnedChatPanel 방 나가기 확인 없음	중	frontend/src/components/chat/PinnedChatPanel.tsx:18-21	●
79	PhoneVerification 영어 에러 메시지 하드코딩	중	frontend/src/components/auth/PhoneVerification.tsx:64	●

8. 종합 평가

8.1 위험도별 분류

위험도	건수	주요 항목
상	8	#1, #2, #3, #4, #5, #13, #21, #22, #53
중	48	#6-#12, #14-#19, #23-#24, #26, #28-#30, #33-#34, #36-#38, #40, #44-#46, #48-#49, #51, #54, #56-#57, #59-#61, #64, #67-#71, #73-#75, #78-#79
하	23	#20, #25, #27, #31-#32, #35, #39, #41-#43, #47, #50, #52, #55, #58, #62-#63, #65-#66, #72, #76-#77
합계	79	

8.2 우선순위 권고

즉시 수정 (상 위험도 8건):

1. #3 환경 파일 Git 추적 해제 + #4 시드 개인정보 제거
2. #13 MARKET_DATA_URL 기본값 3003→3001
3. #1 Settings 프록시 헤더 + #2 페이지뷰 path 검증
4. #5 accessToken localStorage 제거
5. #53 Kafka 토픽명 수정
6. #21, #22 대량 데이터 메모리 로드 → DB 집계

단기 수정 (중 위험도 48건):

- 보안: #6, #7, #8, #10, #11, #12, #33, #36
- 타입 안전성: #15-#18, #28-#29, #59-#61
- 트랜잭션/무결성: #14, #19, #34
- 인프라: #37-#38, #40, #44-#46, #48-#49, #51, #54, #56-#57
- i18n: #64, #67-#71
- 접근성: #73-#75
- UX: #78-#79

8.3 영역별 성숙도

항목	점수 (5점)	비고
보안	3.0/5	환경파일 추적, 시드 PII, localStorage 토큰, 미인증 엔드포인트
데이터 무결성	3.5/5	any 타입 다수, 트랜잭션 미적용
성능	3.5/5	메모리 로드 패턴, N+1 쿼리
인프라	3.5/5	Kafka 불일치, 모니터링 헬스체크, Redis 인증
빌드/환경	3.5/5	NestJS 버전 불일치, 환경변수 누락
프론트엔드 코드	3.5/5	any 타입, eslint-disable 잔존
i18n	3.0/5	9건 하드코딩 잔존

접근성	3.5/5	모달 ARIA 누락 3건
종합	3.3/5	

8.4 1~3차 대비 현황

차수	발견	수정	스킵	미수정
1차	36	36	0	0
2차	50	45	4	1
3차	0 (검증)	-	-	-
4차	79	0	0	79

본 보고서는 VirtuEx 시스템의 4차 감사 결과이며, 1~3차 감사에서 수정된 이슈는 포함하지 않습니다. 2026-03-02 기준 소스 코드를 대상으로 합니다.